

Enterprise Security Architecture (ESA)

Strategic Design for FinBridge Bank

Author: Arold Medegan

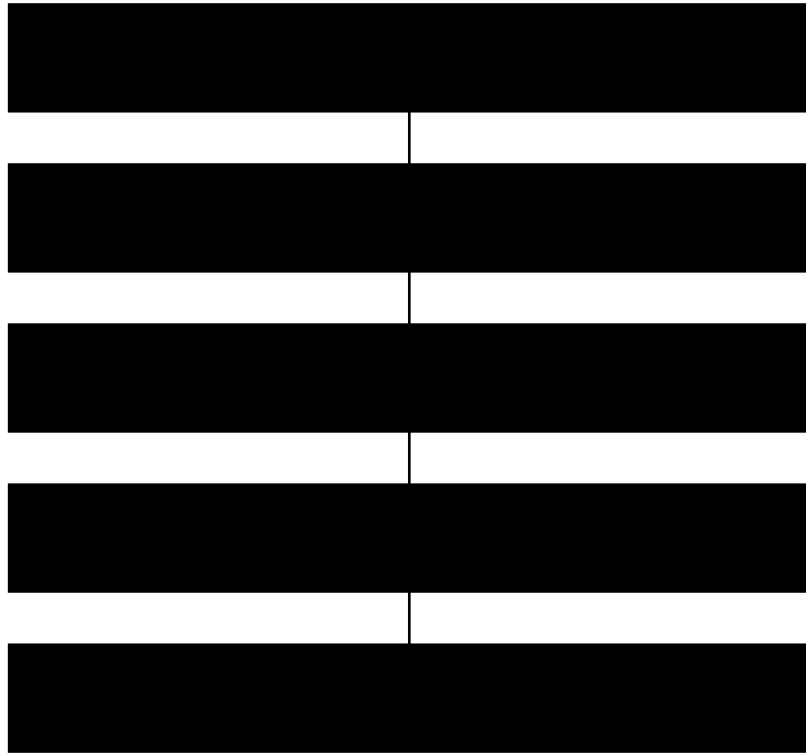
Role Simulation: Junior Enterprise Security Architect

Framework: SABSA | NIST SP 800-53 | ISO 27001 | PCI DSS | GDPR

1. Strategic Business-Risk-Control Alignment

Business Objective	Critical Asset	Risk	Control Strategy	Framework Mapping
Digital Banking Expansion	Customer Data	Data Breach	Encryption, IAM, DLP	ISO 27001 A.8 NIST AC-3
Online Transactions	Payment Systems	Fraud	MFA, Monitoring	PCI DSS Req.8
24/7 Availability	Core Banking	DDoS	Segmentation, IDS/IPS	NIST SC-5
Regulatory Compliance	Personal Data	Non-Compliance	Audit & Logging	GDPR Art.32

2. Multilayer Enterprise Architecture Diagram



3. Zero Trust Architecture Integration

Zero Trust Principle: Never Trust, Always Verify. Implementation includes identity-centric controls, micro-segmentation, least privilege access, continuous authentication, and 24/7 monitoring.

Zero Trust Pillar	Implementation at FinBridge
Identity Verification	Centralized IAM with MFA
Device Security	Endpoint Detection & Response (EDR)
Network Segmentation	Micro-segmentation & NGFW
Continuous Monitoring	SOC + SIEM Real-Time Analytics

4. Risk Matrix (ISO 27005 Methodology)

Threat	Likelihood	Impact	Risk Level	Mitigation
Data Breach	High	High	Critical	Encryption + DLP
Insider Threat	Medium	High	High	Access Monitoring
DDoS Attack	High	Medium	High	Segmentation + Anti-DDoS
Cloud Misconfiguration	Medium	High	High	CASB + Audit

5. Case Study: Equifax Breach – Architectural Failure Analysis

Root Cause: Unpatched vulnerability leading to massive data exposure. Architectural Failure: Weak governance, insufficient vulnerability lifecycle management, lack of segmentation and real-time monitoring.

FinBridge Improvement Strategy: Automated patching, Zero Trust enforcement, continuous vulnerability scanning, executive cyber governance, and SIEM-driven visibility.

6. International References

- SABSA Institute – Business-Driven Security Architecture
- NIST SP 800-53 Rev.5 – Security & Privacy Controls
- ISO/IEC 27001:2022 – Information Security Management Systems
- ISO/IEC 27005 – Information Security Risk Management
- PCI DSS v4.0 – Payment Card Industry Data Security Standard
- EU GDPR Regulation (2016/679)
- The Open Group – TOGAF 9.2